# REDOPS SECURITY ASSESSMENT REPORT

**Automated Enterprise Red Team Assessment & Attack Simulation Platform**
Assessment Date: November 05, 2026 - 20:23:00 UTC | Classification: **CONFIDENTIAL / AUTHORIZED SECURITY ASSESSMENT**

## 1. Executive Summary & Assessment Scope

This document presents the technical findings, topological graph analysis, and simulated attack chains evaluated by the RedOps platform. Testing was conducted exclusively within authorized laboratory scopes and strictly enforce allowlist policies. The assessment evaluated network boundaries, exposed daemon services, correlated CVE records, and synthesized multi-hop lateral movement attack paths toward enterprise crown jewel assets.

| Authorized Scope / Allowlist | Description | Status |
|---|---|---|
| 127.0.0.1 | Safe local testing environment | APPROVED |
| localhost | Local system loopback alias | APPROVED |
| 172.28.0.0/16 | Isolated private Docker network for RedOps assessment | APPROVED |
| 172.28.0.10 | Perimeter Reverse Proxy & Firewall simulation | APPROVED |
| 172.28.0.20 | Internal Spring Boot / Tomcat Application server | APPROVED |
| 172.28.0.30 | PostgreSQL & Redis data stores | APPROVED |
| 172.28.0.40 | Domain Controller and Kerberos authentication server | APPROVED |

## 2. Discovered Assets & Attack Surface

| Host / IP | Hostname | OS / Role | Criticality | Open Ports |
|---|---|---|---|---|
| 172.28.0.10 | gw01.corp.internal | Gateway (Linux) | **HIGH** | 22, 80, 443 |
| 172.28.0.20 | app-portal.corp.internal | Web Server (Linux) | **HIGH** | 8080, 8009, 22 |
| 172.28.0.30 | db-cluster01.corp.internal | Database (Linux) | **CRITICAL** | 5432, 6379 |
| 172.28.0.40 | dc01.corp.internal | DC (Windows) | **CRITICAL** | 88, 389, 445 |

## 3. Correlated Vulnerabilities (NVD / CVE)

| CVE ID | Target Host:Port | CVSS / Severity | Vulnerability Title & Remediation |
|---|---|---|---|
| **CVE-2022-0543** | 172.28.0.30:6379 | 10.0 CRITICAL | **Redis Lua Sandbox Escape Remote Code Execution**<br>Remediation: Upgrade redis-server package to patched distribution release. Enforce requirepass and bind to localhost only. |
| **CVE-2020-1472** | 172.28.0.40:445 | 10.0 CRITICAL | **Microsoft Netlogon Cryptographic Flaw Elevation of Privilege (Zerologon)**<br>Remediation: Apply Microsoft security patch KB4557222 and enforce Secure RPC for all Netlogon connections via registry. |
| **CVE-2022-22965** | 172.28.0.20:8080 | 9.8 CRITICAL | **Spring Framework RCE via DataBinder Access Log Manipulation (Spring4Shell)**<br>Remediation: Upgrade Spring Framework to version 5.3.18 or 5.2.20+. Update Apache Tomcat to 10.0.20, 9.0.62, or 8.5.78. |

| | | | |
|---|---|---|---|
| **CVE-2020-1938** | 172.28.0.20:8009 | **9.8 CRITICAL** | **Apache Tomcat AJP Connector File Read/Inclusion (Ghostcat)**<br>Remediation: Disable the AJP connector in server.xml if not required, or bind to 127.0.0.1 and configure 'requiredSecret'. |
| **CVE-2020-1938** | 172.28.0.20:8080 | **9.8 CRITICAL** | **Apache Tomcat AJP Connector File Read/Inclusion (Ghostcat)**<br>Remediation: Disable the AJP connector in server.xml if not required, or bind to 127.0.0.1 and configure 'requiredSecret'. |
| **CVE-2022-1552** | 172.28.0.30:5432 | **8.8 HIGH** | **PostgreSQL Autovacuum and Index DDL Privilege Escalation**<br>Remediation: Upgrade PostgreSQL to 12.11, 13.7, 14.3 or higher. |
| **CVE-2021-42287** | 172.28.0.40:389 | **8.8 HIGH** | **Active Directory Kerberos Privilege Escalation (sAMAccountName Spoofing)**<br>Remediation: Install KB5008102 and KB5008380 security updates immediately across all domain controllers. |
| **CVE-2021-42287** | 172.28.0.40:88 | **8.8 HIGH** | **Active Directory Kerberos Privilege Escalation (sAMAccountName Spoofing)**<br>Remediation: Install KB5008102 and KB5008380 security updates immediately across all domain controllers. |

## 4. Graph-Based Attack-Path Analysis (NetworkX)

The RedOps graph engine modeled topological asset connectivity and CVE exploitability. Chained paths identify multi-step escalation routes from perimeter vectors to crown jewels.

### • Secondary Domain Hijack Path (AJP Exposure -> Zerologon DC Takeover) (Risk Score: 10.0/10.0 [CRITICAL])

Trajectory: *App Portal Perimeter (172.28.0.20:8009)* → *Domain Controller (172.28.0.40:445)*
Description: Direct attack trajectory bypassing boundary controls through exposed Tomcat AJP port, chaining to internal Domain Controller via Zerologon for forest-level privilege dominance.

### • Primary Enterprise Compromise Chain (Perimeter -> RCE -> Database Exfiltration) (Risk Score: 9.9/10.0 [CRITICAL])

Trajectory: *External Reconnaissance (172.28.0.10:80)* → *Internal Database (172.28.0.30:6379)*
Description: Multi-stage chained attack path enabling an unauthenticated perimeter attacker to exploit Spring4Shell on the application server, pivot to internal Redis on port 6379, and achieve complete database compromise.

## 5. AI Reasoning & Threat Narrative (LLM Module)

### Engine: Local Rule-Based Security Expert Engine (Deterministic Fallback)

EXECUTIVE SECURITY ADVISORY: RedOps Threat Graph Engine identified a high-severity chained attack vector originating from 'App Portal Perimeter (172.28.0.20:8009)' targeting 'Domain Controller (172.28.0.40:445)' with an aggregate risk score of 10.0/10.0.

EXPLOITATION CHAINING ANALYSIS:
1. Initial Access: The perimeter exposes Spring Framework (CVE-2022-22965 / Spring4Shell) on the web tier. An external adversary can submit crafted HTTP POST class-loader parameters to achieve unauthenticated Remote Code Execution.
2. Lateral Movement & Pivoting: The application container shares an unsegmented internal network bridge with the database cluster. Unrestricted TCP connectivity allows direct pivoting to Redis on port 6379.
3. Root Host Escalation: By exploiting CVE-2022-0543 (Redis Lua Sandbox Escape), the attacker executes OS system commands under high privileges, extracting production credentials and achieving complete data exfiltration.

*Limitations & Advisory Notice: ADVISORY NOTICE: Generated by RedOps Local Rule-Based Security Expert Engine based on NetworkX attack path topology and CVSS 3.1 criteria. No live command execution*

*was triggered. Recommendations require security review before change-window deployment.*

## 6. Controlled Simulation Observations

| Scenario Code & Name | Target | Approved By | Status & Observations |
|---|---|---|---|
| **SIM-DISC-01**<br>Safe Network Port & Service Footprinting | 172.28.0.10:80 | security_officer_admin | **[COMPLETED]** Verified open perimeter attack surface on Gateway host. Ports 80 and 443 accept connections. |
| **SIM-EXPLOIT-04**<br>Non-Destructive Vulnerability Signature Verification | 172.28.0.20:8080 | security_officer_admin | **[COMPLETED]** Spring4Shell signature matched on endpoint /api/v1/health. Target application is exposed to remote exploitation. |

## 7. Prioritized Remediation Roadmap

| Priority Level | Target Focus | Defensive Action Plan |
|---|---|---|
| **P0 - IMMEDIATE** | app-portal (172.28.0.20) | Apply vendor patches for Spring4Shell (CVE-2022-22965) and disable Tomcat AJP 8009 (Ghostcat). |
| **P1 - HIGH** | db-cluster01 (172.28.0.30) | Upgrade Redis package, enforce 'requirepass' authentication, bind 6379 to 127.0.0.1. |
| **P2 - MEDIUM** | dc01 (172.28.0.40) | Deploy KB4557222 to block Zerologon Netlogon spoofing. |
| **P3 - ARCHITECTURAL** | All Lab Segments | Implement network microsegmentation between DMZ and database clusters. |